

Project ATLAS — Day 3 Session Log: Attack Simulation

Step-by-step record of work performed, with rationale, for SC200 study and SOC Analyst portfolio purposes

Ivan

July 3–4, 2026

Overview

Today's session executed **Day 3 (Attack Simulation)** of Project ATLAS: a self-built SOC Tier 1 simulation using Microsoft Sentinel, Azure Monitor Agent (AMA), Sysmon, and a Kali Linux attacker VM against a Windows 11 victim endpoint (DESKTOP-TRF9U79). All attacks were generated from a Kali Linux ARM64 VM (VirtualBox, 10.0.2.15) communicating with the Windows 11 VM via NAT port forwarding (host 10.0.2.2:33389 → guest 3389), running on a MacBook Air M4.

The session covered four attack techniques, in order:

1. RDP brute-force password spray using Hydra (T1110.001)
2. Encoded PowerShell execution for defence evasion and remote enumeration (T1059.001 + T1027)
3. Credential harvest phishing simulation via Microsoft Attack Simulation Training (T1566.002)
4. Tor Browser anonymous sign-in to trigger Entra ID Protection risk detection (T1078.004 + T1090.003)

Each section below explains **what was done**, **how it was done**, and — most importantly for interview purposes — **why it was done**, tied back to real SOC analyst responsibilities.

Part A — RDP BruteForce with Hydra (T1110.001)

The attack

From Kali Linux, Hydra was used to attempt a credential stuffing attack against the Windows 11 VM's RDP service, forwarded to the Mac host at port 33389. The command run:

```
hydra -l soclab-test -p Password1 -t 1 rdp://10.0.2.2:33389
```

Result and lab constraint

Hydra returned **0 valid passwords found**. The root cause is a known limitation of Hydra's experimental RDP module: Windows 11 enforces Network Level Authentication (NLA) during the TLS handshake phase, before any credential exchange occurs. Hydra's rdp:// module cannot negotiate NLA, so it fails silently even against a correct username/password pair. NLA was disabled in Windows System Properties to attempt mitigation, but NLA enforcement also exists at the

network policy level on Windows 11, meaning the module's handshake still fails.

Critically, the *attempt* itself generated Windows Security Event ID 4625 (failed logon) entries on DESKTOP-TRF9U79, which are captured by the SecurityEvent Data Collection Rule deployed in Day 2 and surface in Sentinel as brute force telemetry. The attack is documented as “attempted — module limitation” rather than “succeeded,” which mirrors a realistic SOC scenario: defenders often encounter partial telemetry from tools that fail at the transport layer but still leave authentication artefacts on the target.

Challenges encountered

Several CLI errors occurred that are worth documenting: the binary was repeatedly typed as hydra-1 (numeral) instead of hydra; the -l (lowercase L) flag was misread as -1 (numeral one); and a password file at /tmp/passsswords.txt (triple s) was not found after VM reboot because /tmp is volatile. Each was corrected by switching to the inline -p flag and re-running. These reflect realistic CLI familiarity challenges in ARM64 Kali environments where clipboard sharing is unavailable.

MITRE ATT&CK mapping

Credential Access (T1110) → Brute Force, sub-technique T1110.001 (Password Guessing).
Severity: Medium.

Why this matters

Brute force RDP attacks are among the most common initial access vectors in enterprise incidents. Being able to simulate the attack, identify the telemetry it produces (Event ID 4625), and understand why a tool's output may be misleading directly reflects the “analyze logs, alerts, and telemetry from security tools” and “lead and support incident response activities” responsibilities in the target role.

Part B — Encoded PowerShell Execution (T1059.001 + T1027)

The attack

On the Windows 11 VM, a two-step PowerShell sequence demonstrated defence evasion via base64-encoded commands. First, a netcat listener was stood up on Kali to simulate a C2 receiver:

```
nc -lvnp 4444
```

Then on Windows, the payload was generated and executed live within an existing PowerShell session:

```
$e=[Convert]::ToBase64String([Text.Encoding]::Unicode.GetBytes('whoami'))  
powershell -enc $e
```

Output: desktop-trf9u79\ivan — confirming the encoded command executed successfully under the current user context. This Sysmon Event ID 1 (process creation) log entry is what the Day 2 custom analytics rule ATLAS — Encoded PowerShell execution is designed to detect.

Why self-generating the base64 was necessary

The standard approach of pre-computing a base64 string externally and pasting it into the Windows VM failed because VirtualBox on ARM64 does not support bidirectional clipboard sharing — the virtualbox-guest-x11 package is unavailable on ARM64 Kali. Generating the payload inside the same PowerShell session eliminated the dependency. This is a realistic constraint workaround, not a simplification of the technique — real adversaries adapt their delivery mechanism to the available channel.

MITRE ATT&CK mapping

Execution (T1059.001 – PowerShell) + Defence Evasion (T1027 – Obfuscated Files or Information). Severity: High.

Why this matters

Encoded PowerShell is one of the most frequently abused living-off-the-land techniques in real-world intrusions. This session provides the real attack telemetry that the Day 2 detection rule was designed to catch, closing the loop between detection engineering and adversary simulation — a key competency called out in “improve detection, response, and alerting capabilities.”

Part C — Phishing via Attack Simulation Training (T1566.002)

The attack

Microsoft 365 Defender's **Attack Simulation Training** was used to launch a **Credential Harvest** phishing simulation. A “Baseline Credential Harvest” campaign was created and launched from the M365 Defender portal (security.microsoft.com → Email & collaboration → Attack simulation training → Simulations). The simulation delivered a phishing email from a spoofed sender, linking to a credential-harvesting login page.

Result

The simulation achieved a **100% compromise rate**: 1 of 1 targeted users clicked the phishing link, and 1 of 1 users submitted credentials on the spoofed page. The Attack Simulation Training report confirmed both events. The post-click awareness training page (atemplate.com) loaded correctly, confirming the full simulation lifecycle — delivery, click, credential entry, and training redirect — completed successfully.

MITRE ATT&CK mapping

Initial Access (T1566) → Phishing, sub-technique T1566.002 (Spearphishing Link). Severity: High.

Why this matters

Phishing remains the leading initial-access vector in enterprise breaches. Microsoft Attack Simulation Training is a built-in M365 E5 / Defender for Office 365 P2 capability that SOC teams use to measure user susceptibility and generate realistic telemetry without third-party tooling. Running a simulation and interpreting its results — including the distinction between link-click and

credential■submission events — is directly relevant to “improve detection, response, and alerting capabilities across security tools and platforms.”

Part D — Tor Anonymous Sign■in and Entra ID Protection Detection (T1078.004 + T1090.003)

The attack

A test user account (soc-tor-test@VANPASSSC200.onmicrosoft.com) was created in Microsoft Entra ID and assigned an Entra ID P2 licence (required for Identity Protection risk detection features). The account password was reset via the Entra admin centre using the correct path: Users → All users → click the user’s display name → Reset password in the top toolbar. (Note: the left■nav “Password reset” item opens the tenant■wide SSPR configuration page instead — a common navigation trap that caused delays.)

Tor Browser on the Mac was used to sign in to login.microsoftonline.com as soc-tor-test@VANPASSSC200.onmicrosoft.com. The Kali VM had no internet connectivity, making torbrowser-launcher installation impossible — using the Mac directly was the correct pivot. The sign■in succeeded (the “no permission to access this resource” result is expected, since the test account has no M365 role assignment, but the authentication event is logged regardless).

Entra ID Protection detection confirmed

Navigating to entra.microsoft.com → ID Protection → Risky sign■ins (via the Shortcuts row on the Entra home page) revealed five sign■in events flagged At risk, sourced from Tor exit■node IP addresses in Germany (2a03:4000:46:197:b434:d3ff:fe68:d9e1, Karlsruhe, Baden■Württemberg) and Sweden (2a0f:df00:0:255::194). Opening the Risk info tab on the top entry confirmed two detection types:

- **Anonymous IP address (At risk)** — Entra’s ML■based detection for sign■ins from known Tor exit nodes and anonymous proxies
- **Anomalous token (At risk)** — triggered by token characteristics inconsistent with the account’s baseline, a bonus detection

MITRE ATT&CK mapping

Persistence / Defence Evasion (T1078.004 – Valid Accounts: Cloud Accounts) + Command & Control (T1090.003 – Proxy: Multi■hop Proxy). Severity: High.

Why this matters

Tor■based anonymous sign■ins are real adversary tradecraft used during credential■stuffing and account■takeover campaigns. Entra ID Protection’s “Anonymous IP address” detection is a Microsoft■managed ML model that fires without custom rule authorship, demonstrating how a mature IdP stack detects TTPs that have no obvious log keyword. Understanding the difference between this automated detection and a custom Sentinel KQL rule is a nuance that demonstrates depth in “analyse logs, alerts, and telemetry from security tools, cloud platforms, infrastructure, and

network devices.”

Challenges & Lessons (SOC Relevant)

Real trial and error moments from this session with direct SOC relevance:

- **Tool output vs. endpoint telemetry:** Hydra reporting “0 valid passwords found” does not mean no authentication events were generated. Windows Security log still captured 4625 events. Always verify endpoint telemetry independently of the attack tool’s exit status.
- **ARM64 environment constraints:** No clipboard sharing and no internet on Kali required adapting every multi-step command — self-generating base64 in-session, typing commands individually, using Tab autocomplete. Real SOC labs often have air-gapped or restricted segments; adapting to the environment is a practical skill.
- **Entra navigation precision:** The per-user password reset action and the tenant-level SSPR configuration page look similar and are reached through similar-sounding nav items. Confusing them during a live incident delays response. The correct path for resetting a single user is: Users → All users → click display name → Reset password toolbar button.
- **Identity Protection detection latency:** Risk detections may not appear immediately after a sign-in event. In this lab they populated within minutes, but production environments can take longer, which has SLA implications for incident response.

Status Snapshot

Attack / Step	Technique	Outcome
Hydra RDP brute force	T1110.001	Attempted — NLA blocked Hydra module; 4625 events generated on endpoint
Encoded PowerShell (whoami)	T1059.001 + T1027	Complete — output confirmed: desktop-trf9u79\ivan
Phishing simulation (credential harvest)	T1566.002	Complete — 100% compromised (1/1 clicked, 1/1 credentials)
Tor anonymous sign-in	T1078.004 + T1090.003	Complete — sign-in successful; Anonymous IP address + Anomalous token detections confirmed in Entra ID Protection

Next session — Day 4: Investigation & Containment

1. Open Microsoft Sentinel Incidents and triage the alerts generated by today’s attacks (brute-force logon spike, encoded PowerShell, phishing clicks).
2. Investigate the incident timeline, entity graph, and related events in the Sentinel investigation experience.
3. Contain the simulated compromised endpoint (DESKTOP-TRF9U79) using available network isolation controls.

4. Remediate the Entra ID risky user: confirm■compromised, dismiss risk, and reset credentials.
5. Document findings in an Incident Report (the Day 4 deliverable).